

Sécurisation d'un serveur Linux :

1. Objectifs et contexte

L'objectif de cette documentation est de présenter les principales mesures de sécurisation à appliquer sur un serveur Linux exposé sur le réseau (serveur web, serveur FOG, etc.). Les actions décrites couvrent l'accès distant (SSH), la gestion des comptes, le filtrage réseau, la surveillance des journaux et la mise à jour automatique du système.

2. Sécuriser l'accès SSH

SSH permet d'administrer le serveur à distance en ligne de commande.

Installation du service :

```
bash
sudo apt install openssh-server
```

Édition de la configuration :

```
bash
sudo nano /etc/ssh/sshd_config
```

Paramètres recommandés :

```
text
Port 2025          # Changer le port par défaut 22
ClientAliveInterval 600 # Timeout d'inactivité
ClientAliveCountMax 0
PermitRootLogin no   # Interdire la connexion directe de root
```

Redémarrage du service :

```
bash
sudo service ssh restart
```

Exemple de connexion :

```
bash
ssh -p 2025 utilisateur@IP_DU_SERVEUR
```

3. Gestion des comptes et des privilèges

Une bonne gestion des comptes limite l'impact d'un compte compromis.

Changer le mot de passe du compte root :

```
bash
```

```
sudo passwd root
```

Créer un compte administrateur dédié :

```
bash
sudo adduser im
sudo apt install sudo
sudo usermod -aG root,sudo,adm,sshusers im
```

Restreindre les connexions SSH à certains utilisateurs et groupes :

```
bash
sudo nano /etc/ssh/sshd_config
```

```
text
PermitRootLogin no
Port 2025
AllowUsers im
AllowGroups sshusers
```

Ces mesures réduisent la surface d'attaque et imposent un passage par un compte non-root pour l'administration.

4. Mettre en place un pare-feu

Un pare-feu permet de bloquer tout le trafic non nécessaire et de n'ouvrir que les ports utiles (SSH, HTTP/HTTPS, etc.).

4.1 Installation d'iptables

```
bash
sudo apt install iptables
```

4.2 Création de règles de base

Autoriser le port SSH personnalisé (ex. 2025) :

```
bash
sudo iptables -A INPUT -p tcp --dport 2025 -j ACCEPT
```

Ajouter ensuite les ports nécessaires aux services (HTTP 80, HTTPS 443, autres services spécifiques).

Bloquer tout autre trafic entrant :

```
bash
sudo iptables -A INPUT -j DROP
```

Vérifier les règles actives :

```
bash
sudo iptables -L -v
```

Réinitialiser toutes les règles si besoin :

```
bash
sudo iptables -F
```

5. Surveillance et bannissement automatique (Fail2ban)

Fail2ban analyse les journaux des services (SSH, Apache, etc.) pour détecter les tentatives répétées de connexion et bannir automatiquement les IP suspectes.

5.1 Installation

```
bash
sudo apt install fail2ban
```

Copie du fichier de configuration :

```
bash
sudo cp /etc/fail2ban/jail.conf /etc/fail2ban/jail.local
```

5.2 Paramètres généraux

Dans `/etc/fail2ban/jail.local` :

```
text
bantime = 600 # Durée du bannissement (secondes)
findtime = 600 # Fenêtre de temps d'analyse
maxretry = 3 # Nombre de tentatives avant bannissement
```

5.3 Activation de la protection SSH

Créer un fichier dédié :

```
bash
sudo nano /etc/fail2ban/jail.d/custom.conf
```

Exemple minimal :

```
text
[sshd]
enabled = true
```

Redémarrer Fail2ban et vérifier l'état :

```
bash
sudo service fail2ban restart
sudo fail2ban-client status
```

6. Mise à jour automatique du serveur

Des mises à jour régulières réduisent les failles de sécurité liées aux paquets obsolètes.

6.1 Mise à jour des dépôts

```
bash
sudo apt-get update
```

6.2 Outils possibles

Deux approches sont illustrées dans les documents :

- Avec unattended-upgrades :

Installation :

```
bash
sudo apt install unattended-upgrades
```

Configuration :

```
bash
sudo nano /etc/apt/apt.conf.d/50unattended-upgrades
sudo cp /usr/share/unattended-upgrades/20auto-upgrades /etc/apt/apt.conf.d/20auto-upgrades
sudo nano /etc/apt/apt.conf.d/20auto-upgrades
```

Test en mode simulation :

```
bash
sudo unattended-upgrades --debug --dry-run
```

- Avec cron-apt (surveillance / mise à jour automatique par cron) :

```
bash
sudo apt install cron-apt
```

Les journaux d'unattended-upgrades sont consultables dans :

`/var/log/unattended-upgrades/unattended-upgrades.log`

Cette documentation montre comment renforcer un serveur Linux en combinant plusieurs mesures complémentaires : durcissement de l'accès SSH, gestion des comptes, pare-feu, Fail2ban et mises à jour automatiques.

En appliquant ces bonnes pratiques, l'administrateur réduit la surface d'attaque et pose une base solide pour la sécurité globale de l'infrastructure.